A3-PS007-TC042

Privacy-Aware IPv6 IoT Security Monitoring Across Address Rotation

NISHANT MAJUMDAR
nishantmajumdar2@gmail.com
SAYAN GHOSH
sayangh2007@gmail.com
DR. AVIJIT MONDAL
avijit.mondal@sxuk.edu.in

AIORI Hackathon 3 – The Network Project

Problem Description

- RFC 8981 devices rotate their temporary IPv6 addresses to prevent internet-wide tracking [1].
- On a local network, the same rotation defeats per-IP monitoring. A compromised IoT device can flood the link or send rogue Router Advertisements while changing its source address, so each address stays below any per-IP threshold.
- Tracking devices by MAC address would solve attribution, but it is hardware fingerprinting and defeats the privacy goal specified for the topic. Mac addresses can also be randomized via RFC 9724.
- We propose a monitoring pipeline that detects rogue RAs and abnormal Neighbor Discovery rates across address rotations, using short-lived local pseudonyms and authenticated sessions.
- It will use no persistent hardware identifier, no behavioural fingerprinting, no permanent identity recovery, and make no claim of zero tracking risk.

Background

It should capture the background necessary to understand the problem and the proposed optimization

SLAAC and temporary addresses. Hosts build addresses from Router Advertisements [3] and regenerate temporary interface identifiers periodically [1].
Neighbor Discovery. NS, NA, RS, RA and Redirect messages are unauthenticated by default [2], so any host on the link can forge them.
Why IoT. Devices are cheap, rarely patched, easy to compromise, and cannot run monitoring agents.
The gap. Administrators need to attribute abuse to one device across rotations without a permanent identifier. We take the narrow path: attribution only for the lifetime of a short session, bound to a pseudonym that expires.

Literature & RFC Review

Source	What it provides	Relevance / gap for PS-007
RFC 8981 [1] & RFC 7217 [8]	Defines temporary IPv6 address rotation and stable opaque identifiers.	Defines the exact address rotation we must handle. We explicitly do not rely on stable opaque identifiers.
RFC 4861 [2] & RFC 4862 [3]	Defines Neighbor Discovery (ND) message formats and Duplicate Address Detection (DAD) behavior.	Forms the fundamental baseline that our detectors and address-binding logic build on.
RFC 6104 [4] & RFC 6105 [5]	Covers the rogue Router Advertisement (RA) problem and introduces RA-Guard.	RA-Guard provides static, port-based filtering, but it fundamentally does not address rate abuse or IP rotation.
RFC 3971 (SEND) [6]	Gives cryptographic Neighbor Discovery protection.	Needs per-device keys and certificates. This is rarely deployed on IoT devices, rendering it impractical for our environment.
RFC 6583 [7]	Describes neighbor-cache exhaustion problems.	This vulnerability directly motivates the implementation of our distinct-target detector.
RFC 8995 (BRSKI) [9]	Outlines a production enrollment path.	We cite this purely as future work for production scaling and do not build it for this prototype.

Takeaways applied in our design

- Existing defences rely entirely on static filters or fingerprint-based tracking.
- We abandon hardware tracking and instead combine short-lived pseudonyms with rotation-aware attribution.
- We implement dynamic rate and distinct-target cardinality detection to cover the gaps left by static port filtering.

Proposed Solution

A passive, agent-free monitoring pipeline on one IPv6 LAN: 1 router, 5 emulated IoT devices, 1 monitor.
Attribute by attachment, not by identifier. The switch mirrors traffic to the monitor with a per-port tag that stands in for an authenticated link session (802.1X/RADIUS-style). The monitor never reads or stores MAC addresses, hostnames, or any permanent identifiers.
Follow rotation. When a device rotates its address, the monitor learns the new address from the standard DAD Neighbor Solicitation on that port and binds it to the session's pseudonym.
Short-lived pseudonyms. P = `HMAC(K_epoch, tenant ‖ session_id)`. Epoch keys are wiped, mappings expire on a TTL, and a hard session limit forces a fresh, unlinkable pseudonym. Tenant is part of the HMAC domain, so there is no cross-tenant correlation.
Detect by protocol conformance.

- Rogue RAs: unauthorized source, unexpected prefix or flags, lifetime 0.
- Abnormal NDP: per-type rate budgets with hysteresis, plus distinct-target cardinality, all accounted per pseudonym instead of per IP.

Optional fallback. An authenticated agent with a replay-protected key ratchet, for segments where per-port attribution is unavailable.
Two attacks to simulate:

- Rogue RA, including a lifetime-0 variant.
- Rotating NS/NA flood.

Testbed feasibility confirmed. Mininet with `radvd` and real RFC 8981 rotation runs today.
Explicit limits. No behavioural fingerprinting, no permanent identity recovery, no claim of zero tracking risk. Residual risks (within-session linkage, tiny anonymity set, compromised monitor, timing side channels) will be analysed in the final report.
Production Wireless Scalability: In enterprise environments, Access Points utilize 802.1X or MAC Authentication Bypass (MAB) for Dynamic VLAN Assignment, isolating each wireless IoT client into a unique micro-VLAN. By the time this wireless traffic reaches our Open vSwitch monitor, it is already pre-tagged with a distinct VLAN ID, seamlessly replacing the physical switch port as our stable, privacy-preserving session anchor.

Optimization Proposed

List of optimizations and enhancements. Use a table to compare before and after scenarios.

Aspect	Before (per-IP / MAC-based)	After (PS-007)
Attribution key	Source IP (breaks on rotation) or MAC (fingerprinting)	Short-lived pseudonym from an epoch key
Rotating NDP flood	Missed by per-IP limiter	Caught by pseudonym-level accounting
Rogue RA	Not covered by rate limits	Caught by RA validity checks
Burst handling	Rate thresholds on raw counts	Protocol-shaped DAD allowance, token budgets, hysteresis
Low-and-slow	Undetected	Narrowed with CUSUM and target cardinality
Identity lifetime	Permanent	Expires on TTL, keys wiped

Scenario	Baseline (per-IP limiter)	Target for PS-007
Rogue RA	Expected to miss	TPR ≥ 95%, FPR ≤ 1%
Rotating NDP flood	Expected to miss	TPR ≥ 90%, p95 latency ≤ 2 s
Benign stress (simultaneous rotation, reboot, bursty sensor)	n/a	FPR ≤ 2%
Low-and-slow NDP	Undetected	Report the detection-vs-rate curve and its blind boundary

Solution Architecture & Design

Visual: Flowchart or diagram showing the optimization process.

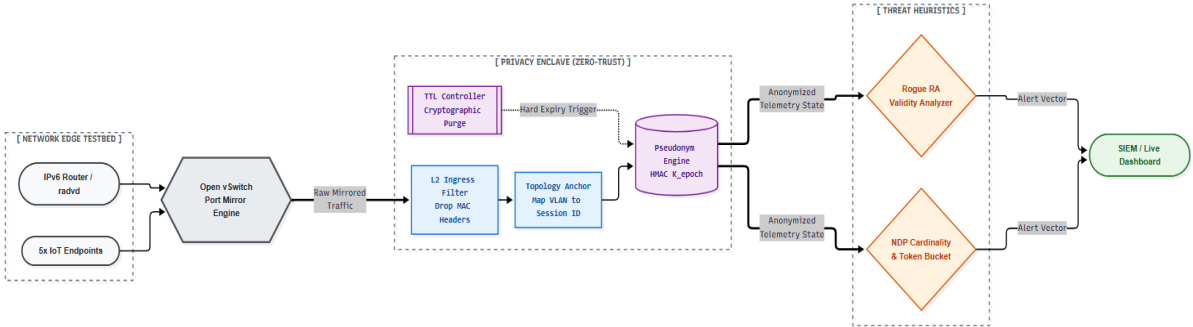


Figure: System Architecture UML Diagram

Data Flow Diagram

Overview of the architecture. Include the flow chart diagram created earlier. Visual:

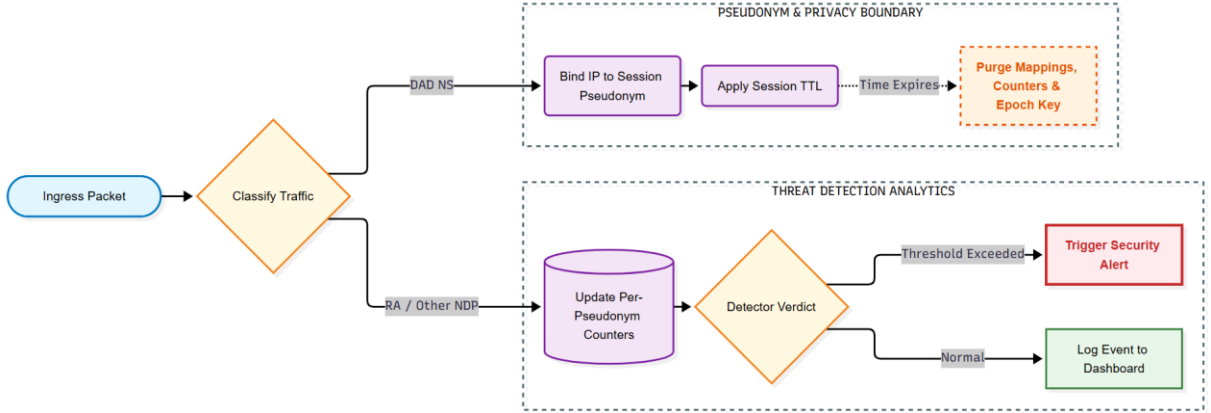


Figure: Data Flow Diagram (DFD)

Deployment Timeline

Clearly define the deployment milestones and methodology.

1. **Oct 3-5:** problem analysis, architecture, testbed feasibility check.
2. **Oct 6-10:** Design topology in Mininet, set up Open vSwitch
3. **Oct 14:** proposal pitch.
4. **Oct 16-20:** pseudonym and attribution modules, monitoring pipeline.
5. **Oct 21-24:** rogue RA and NDP detectors, both attacks, per-IP baseline.
6. **Oct 25-28:** live evaluation, sweeps, and privacy tests (expiry, cross-tenant isolation, no cross-epoch linkage).
7. **Oct 29-31:** dashboard with replay, final report, demo, repo handover.
8. **Future work:** production enrollment (BRSKI, DPP) and multi-segment deployment.

Bibliography I

[1] RFC 8981, *Temporary Address Extensions for Stateless Address Autoconfiguration in IPv6* (2021)
[2] RFC 4861, *Neighbor Discovery for IP version 6 (IPv6)* (2007)
[3] RFC 4862, *IPv6 Stateless Address Autoconfiguration* (2007)
[4] RFC 6104, *Rogue IPv6 Router Advertisement Problem Statement* (2011)
[5] RFC 6105, *IPv6 Router Advertisement Guard* (2011)
[6] RFC 3971, *SEcure Neighbor Discovery (SEND)* (2005)
[7] RFC 6583, *Operational Neighbor Discovery Problems* (2012)
[8] RFC 7217, *A Method for Generating Semantically Opaque Interface Identifiers with IPv6 SLAAC* (2014)
[9] RFC 8995, *Bootstrapping Remote Secure Key Infrastructures (BRSKI)* (2021)

Thank You for Your Attention!